

NATIONAL WORK SAFETY DEPARTMENT (NWSD) RISK ANALYSIS

Author: Anthony Mackenzi
Master of Cyber Security Candidate
RMIT University, Melbourne, Victoria, Australia

About the Author:

Anthony Mackenzi is a *Master of Cyber Security student at RMIT University in Melbourne, Australia*, with a strong interest in cybersecurity, digital risk management, and emerging security technologies.



Table of Contents

01 EXECUTIVE SUMMARY	3
02 INTRODUCTION	4
03 FACT FINDING AND METHODOLOGY	5
OVERVIEW OF INFORMATION DISCOVERY APPROACH	5
SYSTEM AUDIT AND DOCUMENT REVIEW	7
ASSET IDENTIFICATION	7
4. QUANTITATIVE RISK ANALYSIS.....	8
(REFER APPENDIX B FOR - 4.2 OVERVIEW OF IDENTIFIED ASSETS AND THREATS, 4.3 SAMPLE CALCULATIONS AND SUPPORTING JUSTIFICATIONS).....	8
4.5 SUMMARY TABLE OF KEY ASSETS	9
5. QUALITATIVE RISK ANALYSIS	10
5.1 OVERVIEW	10
5.2 SELECTED HIGH-PRIORITY THREATS	10
(REFER APPENDIX C ON 5.3 RISK ANALYSIS PROCESS)	10
5.4 CONCLUSION	10
6. RECOMMENDATIONS AND MITIGATION PLAN	11
6.1 SUMMARY OF PROPOSED CONTROLS	11
6.2 CONTROL EFFECTIVENESS AND RETURN ON INVESTMENT	12
(REFER APPENDIX D FOR 6.3 FIVE-YEAR IMPLEMENTATION ROADMAP AND 6.4 BUDGET ALLOCATION STRATEGY)	13
6.3 FIVE-YEAR IMPLEMENTATION ROADMAP	13
6.4 BUDGET ALLOCATION STRATEGY	14
7. CONCLUSION.....	15
REFERENCE LIST	16
APPENDIX A - ON RISK MATRIX BEFORE AND AFTER VISUALISATION	17
APPENDIX B - 4.2 OVERVIEW OF IDENTIFIED ASSETS AND THREATS AND 4.3 SAMPLE CALCULATIONS AND SUPPORTING JUSTIFICATIONS	20
4.2 OVERVIEW OF IDENTIFIED ASSETS AND THREATS.....	20

4.3 SAMPLE CALCULATIONS AND SUPPORTING JUSTIFICATIONS.....	20
APPENDIX C - 5.3 RISK ANALYSIS PROCESS	21
APPENDIX D- 6.3 FIVE-YEAR IMPLEMENTATION ROADMAP AND 6.4 BUDGET ALLOCATION STRATEGY.....	23
6.4 BUDGET ALLOCATION STRATEGY	24

01 Executive Summary

The National Work Safety Department (NWSD) is at a high risk of cyberattacks because its regulator portal is getting outdated, also its systems are not well integrated, and it doesn't have strong identity management. We used a structured discovery process that included stakeholder interviews, document reviews, system walk-throughs, and a Likert-based survey to find five high-priority threat vectors: (1) weaknesses in identity and access management (IAM), (2) exposure to legacy system/data migration, (3) phishing and social engineering, (4) insider threats, and (5) risks of API and inter-agency data sharing.

Our suggestions are based on a mix of quantitative and qualitative methods. We figured out the Annualised Loss Expectancy (ALE) for each risk and the Return on Security Investment (ROSI) for each candidate control. We used a 5×5 likelihood–impact matrix to show board members how risk changed "before" and "after" and to make uncertainty clear. The two analyses agree: identity-centric controls and modernisation of the portal/network edge lead to the biggest drops in ALE. Phishing and API security come next, and insider risk shows lower but still significant returns.

What we recommend now

- **Identity first:** Set up a central IAM (like Okta or Azure AD), require MFA, and give people access based on their roles, with access reviews happening all the time. This one programme lowers ALE the most and lets you use Zero-Trust principles all over the estate.
- **Modernise the Legacy Parameter :** While moving to a modern platform, use next-gen WAF, enforce TLS 1.3 end-to-end, and encrypt regulated data both when it is at rest and when it is being sent.
- **Blend technical and human defences against phishing:** Combine targeted awareness and micro-learning with email security measures and simulations. Empirical evidence indicates that individual susceptibility to phishing is variable and challenging to predict, thereby supporting the necessity for layered controls in addition to training alone (Sommestad & Karlzén 2024).
- **Constrain insider blast-radius:** Improve screening, least-privilege, and UEBA monitoring; accept a defined residual risk where ROSI is low but keep detective controls and auditability.

- **Secure inter-agency exchange:** Set up an API gateway with mutual authentication, segmentation, and monitoring. Use the right cyber-insurance to cover any remaining risks.

What it costs and what it saves

Within a \$120k/year cap (\$600k over five years), the phased roadmap front-loads IAM and portal protection (Years 1–2), then addresses phishing and API security (Years 3–4) and residual insider risk (Year 5). Across the portfolio we project risk reduction from 60% → 96% over five years. Control-level ROSI ranges from 3.0 to 15.67 (IAM, legacy/WAF/TLS and phishing packages deliver the strongest financial returns). Insider controls are retained for governance and compliance despite lower ROSI.

Why this works

The plan aligns spend with the **largest, fastest ALE reductions**, uses contingency to smooth peaks, and ties every initiative to ISO/IEC 27001 Annex A controls. The result is a defensible, value-for-money path to a secure, resilient and compliant regulator portal that improves service quality, protects citizen data and strengthens public trust.

02 Introduction

The National Work Safety department is experiencing an immense level of cybersecurity issues, considering a critical concern impacting its operations. The outdated portal, inefficient systems and lack of governance framework are critical root causes that lack focus of improvement for technological enhancement.

To address these challenges, the NSWSD have decided to develop a modern integrated platform to provide better performance and support adhering to compliance regulatory functions. Furthermore, this includes strategies for enhancement of current procedures and frameworks to improve technical securities to address vulnerabilities.

Aligning the security goals to current organizational objective is important to ensure essential risks are reduced whilst maintaining operational performance. This will be implemented with scope refinement strategies to ensure organization's commitment to protect assets ensuring

business continuity. In addition, a clear business scope will be defined to prove the need of budget allocation considering the necessity of improvement, with risk management plan to ensure long term reliability.

The report will utilize a structured fact-finding process to determine the key five risks to indicate threats and vulnerabilities. This will be followed by executing an effective qualitative and quantitative of analysis to determine value of contingency reserves and the operational threats. In addition, a sensible budget plan will be constructed to overcome the existing risks to improve business continuity. Finally, the report provides important recommendations based of the risk analysis adhered to the conclusion.

03 Fact Finding and Methodology

Overview of Information Discovery Approach

The outdated system and technical infrastructure of NSDW have led to encounter risks having potential impact on its operations. Thus, it is important to identify the key risks based on the identified risks areas for further improvement. The approach focuses highly on people centric for gathering data in NSWD. The risk identification process will follow a Likert scale questionnaire to generate data to understand the vulnerabilities and threats. The questionnaire will focus on understanding the level of risk in the identified areas of NSDW. Furthermore, the five critical risks will be determined on the key risk categories to develop appropriate risk strategies to encounter the threats.

Furthermore, the risk identification process focuses to evaluate strategies on the key assets of NSWD. The assets of NSDW belong to information, people, technology, people and physical entity. The evaluation of risks will be done based on these key assets to outline the impact on financial and non- financial factors.

These techniques were chosen to align the best practices of IT standards and policies to find the current state risks in NSDW. The finding and identification of risks will focus on the alignment of IOS 27000 standards for NSWD to understand and evaluate threats cybersecurity weakness and threats.

The questionnaire is outlined below for discovery of information in relation risks in NSDW. In addition, the above Likert scale questionnaire implies a answering scale of 1 to 5 with scaling details mentioned below.

- 1-Very Low
- 2-Low
- 3-Moderate
- 4-High
- 5-Very High

Format

Identify and Access Management:

- 1.The portal provides the required protection against unauthorized access in NWSD.
- 2.Multi factor authentication must be necessary for all the systems in NWSD.
- 3.Role based accessed control regulations and standards are clear established in NWSD.

Data security:

- 1.I am confident that PII information is stored securely with necessary protection strategies.
- 2.Current processes have the capability of increasing accidental leakage.
- 3.Government standard and policies are complied with current system in NSDW.

System vulnerabilities:

1. The current portal possesses a high cyber security risk.
2. Data manipulation and data loss is high due manual operations.

3. The current complaint submission system is vulnerable to fake submissions or malicious exploitation.

Inter-Agency operations:

1. Current procedures of data sharing with external agencies are secure
2. I am concerned cybersecurity risks may get exposed due to manual sharing of data
3. A modern integrated portal would reduce risks and threats complied to insecure data sharing process.

System Audit and Document Review

A System Audit review will be conducted to gather information to evaluate how current plans of NWSD will be improved with existing technical gap. System walkthroughs and audit log of systems will be monitored to identify the missing security patched and unresolved compatibility issues. Furthermore, the auditing will follow documentation process to highlight the key sensitive areas of NWSD that will encounter high vulnerabilities and risks. This will ensure to re-construct the business process to ensure enhanced security is provided to system with effect risk management plan.

Asset Identification

The associated assets of NWSD were identified by reviewing the business context and verified using relevant technical checks and staff input.

Interview Insights from Technical Security Team.

Interview with technical personals outlined that business continuity and disaster recovery plans were more informative with incompleteness of test. Backup processes, data sharing and

information storing were outdated and lacked redundancy limiting organization for efficiency. In addition, signaling high cyber security risks due to improper technical strategies.

4. Quantitative Risk Analysis

4.1 Methodology: ALE and ROSI

The quantitative risk analysis for the National Work Safety Department (NWSD) was performed using the **Annualized Loss Expectancy (ALE)** method, a recognised approach in cybersecurity risk management. For each risk scenario, three parameters were calculated:

- **Asset Value (AV):** The financial value of the asset based on its role in operations and potential financial exposure.
- **Exposure Factor (EF):** The percentage of asset value lost if a threat materialises.
- **Annual Rate of Occurrence (ARO):** Estimated likelihood of the event occurring per year.

The formula applied:

$$ALE = AV \times EF \times ARO$$

To evaluate cost-effectiveness of controls, the **Return on Security Investment (ROSI)** was also computed:

$$ROSI = \frac{(ALE_{before} - ALE_{after} - ACS)}{ACS}$$

Where ACS is the Annual Cost of Security.

(Refer Appendix B for - **4.2 Overview of Identified Assets and Threats, 4.3 Sample Calculations and Supporting Justifications**)

4.4 ISO/IEC 27001 Control Mapping

Mitigation strategies were mapped to ISO/IEC 27001 Annex A controls, ensuring international compliance:

- **R001 – IAM Vulnerability:** A.9.2.1 – User Registration & De-registration
- **R002 – Legacy System Breach:** A.13.1.1 – Network Controls
- **R003 – Phishing Attacks:** A.7.2.2 – Information Security Awareness & Training
- **R004 – Insider Threat:** A.7.1.1 – Screening

This mapping demonstrates alignment with both **international best practices** and the **Australian Government ISM and PSPF frameworks**.

4.5 Summary Table of Key Assets

Risk ID	Description	ALE (Before)	ALE (After)	ACS (\$)	CBA (\$)	ROSI	Decision
R001	User Accounts	\$1,680,000	\$30,000	\$180,000	\$1,320,000	7.33%	Mitigate
R002	Sensitive Databases	\$900,000	\$100,000	\$120,000	\$1,880,000	15.67%	Mitigate
R003	Employee Credentials & Email	\$1,278,000	\$21,300	\$85,000	\$554,000	65.2%	Mitigate
R004	Internal Systems	\$300,000	\$120,000	\$95,000	\$55,000	0.58%	Accept

Table 1 – ALE and ROSI Results for Key NWSD Risks

5. Qualitative Risk Analysis

5.1 Overview

This section provides a qualitative assessment of NWSD's key cybersecurity risks, complementing the earlier quantitative analysis. Using a **5×5 risk matrix**, we illustrate how ISO/IEC 27001:2013-aligned controls reduce both **likelihood** and **impact** of critical threats and communicate those changes clearly to mixed technical/non-technical audiences. We also reflect current scholarship that cautions against overconfidence in risk quantification and underscores the need to combine qualitative judgement with quantitative models (Simpson, 2024). (Refer Appendix A - on Risk Matrix Before and After visualisation)

5.2 Selected High-Priority Threats

Based on ALE and operational significance (from your spreadsheet), five threats were prioritised:

1. **Identity & Access Management (IAM) vulnerability** (User Accounts)
2. **Legacy system data breach** (Sensitive Databases)
3. **Phishing** (Employee Credentials & Email)
4. **Insider threat** (Internal systems & confidential data)
5. **API security weaknesses** (External interfaces)

(Refer Appendix C on 5.3 Risk Analysis Process)

5.4 Conclusion

The qualitative analysis indicates that targeted, ISO-compliant mitigations—particularly zero-trust-focused IAM, segmented networks, and integrated anti-phishing initiatives—yield significant reductions in organisational risk. These findings are consistent with contemporary

research that (i) recognises identity and visibility as zero-trust critical success factors (Yeoh et al., 2023), (ii) advocates for the calibration of awareness initiatives due to variable effectiveness (Marshall, Sturman & Auton, 2024), and (iii) emphasises the necessity of explicitly addressing uncertainty in the interpretation of risk matrices and quantitative estimates (Simpson, 2024).

6. Recommendations and Mitigation Plan

6.1 Summary of Proposed Controls

The cybersecurity risk assessment for NWSA identified five critical risks in its regulator portal and supporting ICT environment. Each risk is mapped to tailored mitigation strategies and aligned with ISO/IEC 27001 Annex A controls:

Risk Area	Control Strategy	ISO/IEC 27001 Control
Identity & Access Management (IAM)	Deploy central IAM with MFA, enforce RBAC, and implement continuous access reviews	A.9.2.1 – User registration & de-registration
Legacy Regulator Portal & Data Migration	Introduce next-gen WAF, TLS 1.3, database encryption, and structured migration with hashing/backups	A.13.1.1 – Network controls
Phishing & Social Engineering	Implement phishing simulations, secure mail filters, just-in-time prompts, paired with awareness training	A.7.2.2 – Information security awareness & training

Insider Threats	Strengthen pre-employment screening, deploy UEBA (user and entity behavior analytics) monitoring, and enforce least-privilege access	A.7.1.1 – Screening
API & Inter-agency Data Sharing	Deploy API gateway, enforce mutual authentication and segregation, and transfer residual risk via cyber insurance	A.13.1.3 – Segregation in networks

Rationale / Supporting Evidence:

- Zero-trust IAM architectures (with MFA, least privilege, continuous access validation) are increasingly essential; identity is now central to modern security models (Okta 2022) (Okta 2022; Microsoft 2022).
- Phishing and social engineering are among the highest recurring threats; combining training with technical controls improves efficacy (Safe Security 2024).
- Integrating behavior analytics with IAM helps detect anomalies and insider risk (OpenText 2023).
- Segmented API gateways and network segregation reduce attack surface in inter-agency sharing (Microsoft Zero Trust TEI) (Microsoft 2022).

6.2 Control Effectiveness and Return on Investment

The controls were chosen based not only on technical merit but also financial justification via **ALE / ROSI** metrics:

- **IAM Controls:** ROSI = 7.33, reducing ALE from \$1.68 M to \$30 k.
- **Legacy Portal Protection:** ROSI = 15.67, ALE reduced from \$900 k to \$100 k.
- **Phishing Mitigation:** ROSI = 6.52, ALE from \$1.278 M to \$21.3 k.
- **Insider Threat Acceptance:** ROSI = 0.58, ALE reduction from \$300 k to \$120 k.
- **API Vulnerabilities:** ROSI = 3.0, ALE from \$252 k to \$27 k.

This is in line with what the literature says about ROI/ROSI models helping board members justify Investment on cybersecurity (Check Point 2023) and hybrid models (like FAIR-ROSI) making qualitative and quantitative risk decision-making more closely aligned (He et al. 2024) (He, Xin & Luo 2024).

In addition, studies of vendors in the real world show that Zero Trust implementations can have a high return on investment. For example, Microsoft said that its Zero Trust solutions had a 92% return on investment over three years (Microsoft 2022). So, our IAM and zero-trust investments are not only defensible, but they also make us more competitive.

(Refer Appendix D for 6.3 Five-Year Implementation Roadmap and 6.4 Budget Allocation Strategy)

6.3 Five-Year Implementation Roadmap

A phased roadmap balances technical priorities and budget cycles:

Year	Key Risk Addressed	Major Activities
Year 1	IAM Vulnerabilities	Roll out central IAM (Okta/Azure AD), enable MFA, enforce RBAC
Year 2	Legacy Portal & Migration	Deploy next-gen WAF, enforce TLS 1.3, encrypt databases, perform staged migration
Year 3	Phishing & Awareness	Conduct phishing campaigns, deploy email filters, deliver awareness training
Year 4	API & Secure Data Sharing	Deploy API gateway, implement mutual authentication, set up microsegmentation
Year 5	Insider Threat & Residual Risk	Strengthen screening policies, enable UEBA monitoring, perform periodic IAM audits

This phased strategy front-loads highest ALE reduction controls (IAM, portal) and defers lower-ROSI or residual risks (insider, API) accordingly.

6.4 Budget Allocation Strategy

NWSD's annual cybersecurity budget was capped at **\$120,000 per year**, totaling **\$600,000** over five years. A **contingency reserve** is used to smooth expenditure, with allocations structured to maximize security return while preserving flexibility.

Key elements of the strategy:

- **Risk-based prioritisation:** Largest investments are in control areas with highest ALE exposure (IAM, portal protection).
- **Staggered deployment:** Costly initiatives (e.g. backup systems) are phased across years to avoid budget shocks.
- **Contingency balancing:** Negative reserves in early years (e.g. -\$20,000 in Year 1) enable front-loading critical projects; later surpluses offset earlier deficits.
- **Savings carry-forward:** Surpluses from lower-spend years are reinvested in subsequent years.
- **Deficit offset:** Projects surpassing annual cap are compensated via negative contingency that is gradually reduced.

Financial outcomes:

- Total 5-year allocation = \$600,000
- Cumulative risk reduction trajectory: 60% (Year 1) → 96% (Year 5)
- Investment is aligned with return metrics and budget constraints, supporting sustainable cybersecurity growth

This balanced approach ensures NWSD can mitigate all identified priority risks while maintaining fiscal discipline and strategic alignment.

7. Conclusion

In conclusion, NWSD is dealing with big cybersecurity risks because of legacy architecture, broken systems, weak IAM controls, and manual data processes. We used a structured fact-finding process and a mix of quantitative and qualitative analysis to find five high-priority threat vectors and suggest ways to reduce them that are in line with ISO/IEC 27001.

The ALE and ROSI calculations show that putting investment into IAM, protecting legacy portals, combating phishing attacks, and API security all pays off well. The ROSI values range from 3.0 to 15.67, which means that the costs are worth it. The insider threat control, though lower in ROSI, is not something that can be ignored; given human factors, accepting some residual risk is realistic.

The five-year, \$600,000 budget plan includes safety nets, staggered deployments, and prioritised risk reduction (from 60% in Year 1 to 96% by Year 5). This makes sure that security investments are in line with the goals of the organisation. This method uses risk-based prioritisation, flexibility, and phased execution to get the most protection without going over budget.

So, NWSD is in a good position to turn its regulator portal into a secure, reliable, and compliant digital platform that fixes both technical flaws and governance flaws. Following these plans will lower risk, build public trust, meet regulatory requirements (like government cyber frameworks), and over time, give a measurable return on investment.

Reference List

Anchor Cybersecurity 2025, 'ROI vs. ROSI: Calculating the True Value of Cybersecurity Investments', Anchor Cybersecurity website, accessed on 26th September 25. <https://anchorcybersecurity.com/blog/2025-03-07-CRISC-ROA-ROSI>

Check Point 2023, 'What is ROSI (Return on Security Investment)', Check Point website, accessed on 25th September 25 . <https://www.checkpoint.com/cyber-hub/cyber-security/what-is-rosi-return-on-security-investment>

Marshall, N, Sturman, D & Auton, JC 2024, 'Exploring the evidence for email phishing training: A scoping review', *Computers & Security*, vol. 139, art. 103695, doi:10.1016/j.cose.2023.103695.

Microsoft 2022, *The Total Economic Impact™ of Zero Trust Solutions*, Microsoft website, accessed on 25th September 25 <https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/final/en-us/microsoft-brand/documents/Microsoft-Zero-Trust-TEI-Study.pdf>

Okta 2022, *State of Zero Trust Security 2022*, Okta website, accessed on 24th September 25 https://www.okta.com/sites/default/files/2022-08/OKta_WhitePaper_StateofZeroTrustSecurity_FINAL.pdf

OpenText 2023, *State of Zero Trust in the Enterprise: Shift to Identity-Powered Security*, OpenText website, accessed on 26th September 20. <https://www.opentext.com/assets/documents/en-US/pdf/state-of-zero-trust-in-the-enterprise-shift-to-identity-powered-security-report-en.pdf>

Safe Security 2024, 'Find the ROI of Cybersecurity Tools – Mini Case Study', Safe Security website, accessed on 24th September 25 <https://safe.security/resources/blog/find-the-roi-of-cybersecurity-tools-mini-case-study>

Simpson, A 2024, 'Into the unknown: the need to reframe risk analysis', *Journal of Cybersecurity*, vol. 10, art. tyae022, doi:10.1093/cybsec/tyae022.

Sommestad, T & Karlzén, H 2024, 'The unpredictability of phishing susceptibility: results from a repeated measures experiment', *Journal of Cybersecurity*, vol. 10, no. 1, art. tyae021, doi:10.1093/cybsec/tyae021.

Yeoh, W, Liu, M, Shore, M & Jiang, F 2023, 'Zero trust cybersecurity: Critical success factors and a maturity assessment framework', *Computers & Security*, vol. 133, art. 103412, doi:10.1016/j.cose.2023.103412.

Appendix A - on Risk Matrix Before and After visualisation

Before

		Consequence				
		1 Insignificant	2 Minor	3 Significant	4 Major	5 Severe
Likelihood	5 Almost Certain	5 Medium	10 High	15 Very High	20 Extreme	25 Extreme
	4 Likely	4 Medium	8 Medium	12 High 5. API Security	16 Very High 3. Phishing	20 Extreme
	3 Moderate	3 Low	6 Medium	9 Medium	12 High 4. Insider Threat	15 Very High 2. Legacy System
	2 Unlikely	2 Very Low	4 Low	6 Medium	8 Medium	10 High
	1 Rare	1 Very Low	2 Very Low	3 Low	4 Medium	5 Medium

Very Low	Low	Medium	High	Very High	Extreme
----------	-----	--------	------	-----------	---------

After

		Consequence				
		1 Insignificant	2 Minor	3 Significant	4 Major	5 Severe
Likelihood	5 Almost Certain	5 Medium	10 High	15 Very High	20 Extreme	25 Extreme
	4 Likely	4 Medium	8 Medium	12 High	16 Very High	20 Extreme
	3 Moderate	3 Low	6 Medium	9 Medium 4. Insider Threat	12 High	15 Very High
	2 Unlikely	2 Very Low	4 Low 5. API Security	6 Medium 3. Phishing	8 Medium	10 High
	1 Rare	1 Very Low	2 Very Low	3 Low 1. IAM	4 Medium 2. Legacy System	5 Medium

Very Low	Low	Medium	High	Very High	Extreme
----------	-----	--------	------	-----------	---------

Risk Assessment Summary - Five Priority Threats

Threat	Asset	Before Controls			After Controls			Risk Reduction	ROSI
		L	I	Score	L	I	Score		
1. IAM Vulnerability	User Accounts (\$6M)	4 (Likely)	5 (Severe)	20 Extreme	1 (Rare)	3 (Significant)	3 Low	85%	7.33
Control: MFA, RBAC & Central IAM (Okta/Azure AD) ISO 27001: A.9.2.1 (User registration & de-registration) Decision: MITIGATE									
2. Legacy System Breach	Sensitive Databases (\$5M)	3 (Possible)	5 (Severe)	15 Very High	1 (Rare)	4 (Major)	4 Medium	73%	15.67
Control: Next-Gen WAF + TLS 1.3 + DB Encryption ISO 27001: A.13.1.1 (Network controls) Decision: MITIGATE									
3. Phishing Attack	Employee Credentials (\$4.26M)	4 (Likely)	4 (Major)	16 Very High	2 (Unlikely)	3 (Significant)	6 Medium	63%	6.52
Control: Phishing Simulations + Secure Mail Filters ISO 27001: A.7.2.2 (Information security awareness, education and training) Decision: MITIGATE									
4. Insider Threat	Internal Systems (\$3M)	3 (Possible)	4 (Major)	12 High	3 (Possible)	3 (Significant)	9 Medium	25%	0.58*
Control: Pre-employment checks + UEBA monitoring ISO 27001: A.7.1.1 (Screening) Decision: ACCEPT (Due to low ROSI and inherent human factors)									
5. API Vulnerabilities	APIs (\$1.2M)	4 (Likely)	3 (Significant)	12 High	2 (Unlikely)	2 (Minor)	4 Low	67%	3.00
Control: Cyber insurance + API gateway controls ISO 27001: A.13.1.3 (Segregation in networks) Decision: TRANSFER									

Legend: L = Likelihood | I = Impact | ROSI = Return on Security Investment

* Insider Threat shows lower ROSI - Organization accepts residual risk due to inherent human factors

Appendix B - 4.2 Overview of Identified Assets and Threats and 4.3 Sample Calculations and Supporting Justifications

4.2 Overview of Identified Assets and Threats

Fifteen major risks across NWSD's regulatory and IT landscape were identified. Assets include:

- **User Accounts** (digital identities, authentication)
- **Sensitive Databases** (PII, compliance records, investigations)
- **Employee Credentials and Email Accounts** (phishing, credential theft)
- **Internal Systems and Confidential Data** (insider threats)
- **API Gateways and Connected Applications** (external/public interfaces)

Each risk was analysed under pre-control and post-control conditions, ensuring mitigation strategies aligned with **ISO/IEC 27001** requirements.

4.3 Sample Calculations and Supporting Justifications

Example: User Accounts – Identity & Access Management Vulnerability (R001)

- **AV** = \$6,000,000 (represents value of staff, contractor, and regulated entity user accounts)
- **Pre-control:** EF = 0.35, ARO = 0.8

- $SLE_o = \$2,100,000$
- $ALE_o = \$1,680,000$

Mitigation: MFA, RBAC & central IAM (Okta/Azure AD) (ISO 27001 A.9.2.1 – User registration & de-registration).

- **Post-control:** $EF = 0.1$, $ARO = 0.05$
- $SLE_s = \$600,000$
- $ALE_s = \$30,000$
- $ACS = \$180,000$ annually
- $ROSI = (1,680,000 - 30,000 - 180,000) \div 180,000 = 7.33$

This demonstrates a highly cost-effective mitigation, significantly reducing ALE while aligning with global standards.

Appendix C - 5.3 Risk Analysis Process

5.3.1 Step 1: Risk Identification

The five risks above were chosen due to **high exposure** and **material frequency**, aligning selection with evidence-based governance practice.

5.3.2 Step 2: Likelihood and Impact Rating

A five-point scale was applied for **likelihood** (Rare → Almost certain) and **impact** (Minor → Severe). Likelihood ratings were informed by ARO; impact used asset criticality and pre-control ALE. This approach is consistent with contemporary critiques that recommend transparent assumptions and acknowledgement of uncertainty when mapping qualitative scales to quantitative inputs (Simpson, 2024).

5.3.3 Step 3: Control Selection and Mapping

Controls were selected for ISO/IEC 27001 Annex A alignment **and** demonstrated effectiveness in the literature:

- **Zero-Trust-aligned IAM controls** (central IAM, MFA, least privilege) → A.9.2.1, A.9.4.x. Empirical work identifies **identity, visibility/analytics, and automation** as **critical success factors** for zero-trust adoption—supporting our focus on IAM maturity and continuous monitoring (Yeoh et al., 2023).
- **Security awareness & anti-phishing training** (A.7.2.2) is retained but calibrated: recent **scoping review evidence** finds mixed real-world efficacy across programme types, so we pair training with **technical email controls and reporting workflows** to achieve meaningful risk reduction (Marshall, Sturman & Auton, 2024).

Examples of mappings used:

- IAM vulnerability → **A.9.2.1** (user registration & de-registration)
- Legacy breach → **A.13.1.1** (network controls)
- Phishing → **A.7.2.2** (awareness & training)
- Insider threat → **A.7.1.1** (screening)
- API exposure → **A.13.1.3** (segregation in networks)

5.3.4 Step 4: Matrix Development

We plotted **before/after** positions on the 5×5 matrix:

- **IAM**: Likely–Severe → Rare–Moderate after MFA + central IAM and RBAC.
- **Phishing**: Likely–Significant → Unlikely–Moderate after a combined programme of simulations, just-in-time prompts, and mail-security controls—consistent with literature that advises blended measures rather than awareness alone (Marshall, Sturman & Auton, 2024).
- **Insider threat**: Possible–Significant → remains **moderate** due to inherent residual human factors despite screening/UEBA, which is consistent with calls to acknowledge model limits and residual uncertainty (Simpson, 2024).

5.3.5 Step 5: Justification and Communication

Controls were prioritised on **risk movement** (matrix shift) and **economic value** (ROSI). Our emphasis on **identity-centric** controls and **continuous monitoring** reflects zero-trust critical success factors identified in peer-reviewed studies (Yeoh et al., 2023), while our communication artefacts (heat-maps, assumptions registers) follow guidance to clearly state uncertainties and limitations in risk models (Simpson, 2024).

Appendix D- 6.3 Five-Year Implementation Roadmap and 6.4 Budget Allocation Strategy

6.3 Five-Year Implementation Roadmap

A phased roadmap balances technical priorities and budget cycles:

Year	Key Risk Addressed	Major Activities
Year 1	IAM Vulnerabilities	Roll out central IAM (Okta/Azure AD), enable MFA, enforce RBAC
Year 2	Legacy Portal & Migration	Deploy next-gen WAF, enforce TLS 1.3, encrypt databases, perform staged migration
Year 3	Phishing & Awareness	Conduct phishing campaigns, deploy email filters, deliver awareness training
Year 4	API & Secure Data Sharing	Deploy API gateway, implement mutual authentication, set up microsegmentation
Year 5	Insider Threat & Residual Risk	Strengthen screening policies, enable UEBA monitoring, perform periodic IAM audits

This phased strategy front-loads highest ALE reduction controls (IAM, portal) and defers lower-ROSI or residual risks (insider, API) accordingly.

6.4 Budget Allocation Strategy

NWSD's annual cybersecurity budget was capped at **\$120,000 per year**, totaling **\$600,000** over five years. A **contingency reserve** is used to smooth expenditure, with allocations structured to maximize security return while preserving flexibility.

Key elements of the strategy:

- **Prioritising based on risk:** The biggest investments are in control areas with the most ALE exposure (IAM, portal protection).
- **Staggered deployment:** Expensive projects (like backup systems) are spread out over several years to keep budgets from being shocked.
- **Contingency balancing:** Negative reserves in the first few years (like -\$20,000 in Year 1) let you front-load important projects, and later surpluses make up for earlier deficits.
- **Carrying over savings:** Extra money from years when you spent less is put back into the next year's budget.
- **Deficit offset:** Projects that go over the annual cap are paid for with a negative contingency that gets smaller over time.

Financial outcomes:

- Total 5-year allocation = \$600,000
- Cumulative risk reduction trajectory: 60% (Year 1) → 96% (Year 5)
- Investment is aligned with return metrics and budget constraints, supporting sustainable cybersecurity growth

This balanced approach ensures NWSD can mitigate all identified priority risks while maintaining fiscal discipline and strategic alignment.